

Provas de Segurança

Fundamentos de Criptografia e Segurança da Informação

J. Bacelar Almeida (jba@di.uminho.pt)

Departamento de Informática
Universidade do Minho

Formalização da Segurança

definição de segurança

- Interessa caracterizar formalmente (de forma rigorosa) *o que se entende por segurança de uma primitiva criptográfica*.
- Em particular, pressupõe caracterizar:
 - ① a primitiva criptográfica considerada e qual é o seu objectivo;
 - ② critérios que estabelecem a segurança da primitiva.
- No primeiro ponto, define-se o *Sistema Criptográfico* em análise;
- No segundo, define-se
 - no que consiste um ataque à primitiva;
 - capacidades atribuídas ao adversário
 - interacção que lhe é permitida com o Sistema Criptográfica;
 - informação a que tem acesso (argumentos, oráculos);
 - limitações computacionais (e.g. *Probabilistic Polynomial-Time (PTT)*);

Parte I

Criptografia Simétrica

Sistema Criptográfico

- Uma primitiva criptográfica consiste num conjunto de operações cuja utilização deve ser orquestrada por forma a cumprir com os objectivos pretendidos.
- Exemplo: cifra simétrica
 - KGen: **procedimento probabilístico** de geração da chave;
 - Enc: **procedimento probabilístico** que produz o criptograma correspondente a uma mensagem (para determinada chave)
 - Dec: **procedimento determinístico** que recupera a mensagem do criptograma
- Critério de **correção**: uma cifra $\Sigma = \langle \text{KGen}, \text{Enc}, \text{Dec} \rangle$ diz-se correcta quando

$\text{Correct}^{\Sigma}(m)$

1 : $k \leftarrow \$ \text{KGen}()$

2 : $c \leftarrow \$ \text{Enc}_k(m)$

3 : **return** $\text{Dec}_k(c) = m$

$$\forall m \in \mathcal{M}, \Pr[\text{Correct}^{\Sigma}(m) = \text{true}] = 1$$

Jogos de Segurança

- Interação entre as diversas componentes da análise (operações do sistema criptográfico; adversário; etc.) são capturadas por **experiências probabilísticas**.
- Essas experiências são descritas por programas probabilísticos designados por **Jogos de Segurança**.
- Nesses jogos, considera-se que o adversário “ganha” quando um *ataque* é bem sucedido.
- A segurança será assim estabelecida argumentando que, para qualquer adversário (da classe considerada), a probabilidade de sucesso é “insignificante”.

Funções negligenciáveis

- Interessa capturar o conceito de “probabilidade de sucesso insignificante” (e.g. resultante de uma escolha aleatória num universo muito grande);
- Note-se a natureza *assimptótica* do conceito pretendido – é relativo a um parâmetro de segurança λ (e.g. tamanho da chave)¹; ←
- Uma função diz-se *negligenciável* quando tende para zero mais rápido do que a inversa de qualquer polinómio.

Definition (Função Negligenciável)

Uma função $f : \mathbb{N} \rightarrow \mathbb{R}$ diz-se *negligenciável* ($f \in \text{negl}(\lambda)$) quando, para qualquer $c \in \mathbb{N}$ existe $N_c \in \mathbb{N}$, tal que, para qualquer $k > N$,

$$|f(k)| < k^{-c}$$

chances
difíceis

¹No que se segue, iremos normalmente considerar o parâmetro de segurança λ implícito.

OVERWATCH

Exemplo: função *one-way*

- Defina-se o “jogo” OW que desafia o adversário a inverter a função f :

$OW^f(\mathcal{A})$
1 : $x \leftarrow \$ \{0, 1\}^k$
2 : $y = f(x)$
3 : $x' \leftarrow \$ \mathcal{A}(y)$
4 : return $f(x') = y$

basicamente
pense numa
hash

- A **vantagem** de um adversário $\mathcal{A}$ é definida como a probabilidade de sucesso da experiência:

$$\text{Adv}_{\mathcal{A}}^{\text{ow}} = \Pr[OW^f(\mathcal{A}) = \text{true}]$$

- f é *one-way* quando, para qualquer adversário $\mathcal{A} \in \text{PPT}$:

$$\text{Adv}_{\mathcal{A}}^{\text{ow}} \in \text{negl}(\lambda)$$

Propriedade de Confidencialidade

- Para estabelecer a segurança de uma cifra, devemos garantir a confidencialidade da informação cifrada.
- Já estudamos o critério de “segurança absoluta” [Shannon], que pode ser expressa como: para qualquer par de mensagens $m_0, m_1 \in \mathcal{M}$ e criptograma $c \in \mathcal{C}$,

$$\Pr[\text{Enc}_k(m_0) = c] = \Pr[\text{Enc}_k(m_1) = c].$$

ok não existe favoritismo

- Esse critério pode ser relaxado para considerar a capacidade de um adversário, com limitações computacionais, em distinguir os criptogramas resultantes da cifra de duas mensagens com o mesmo tamanho.

Indistinguibilidade de criptogramas

- Uma forma de capturar a proximidade das duas probabilidades apresentadas consiste em desafiar o adversário a reconhecer qual a mensagem cifrada de entre duas mensagens de igual tamanho por si escolhidas:

IND($\mathcal{A}$)

```
1 :  $k \leftarrow \$ \text{KGen}(1^\lambda)$ 
2 :  $(m_0, m_1, \text{state}) \leftarrow \$ \mathcal{A}_1()$ 
3 :  $b \leftarrow \$ \{0, 1\}$ 
4 :  $c \leftarrow \$ \text{Enc}_k(m_b)$ 
5 :  $b' \leftarrow \$ \mathcal{A}_2(\text{state}, c)$ 
6 : return  $b = b'$ 
```

- Note-se que o adversário intervém em “duas fases” distintas ($\mathcal{A}_1$ e $\mathcal{A}_2$), mas admite-se que preserve a memória entre essas duas fases (através da variável state).

IND-CPA

- O jogo IND apresentado atrás acaba por capturar uma noção de segurança **muito fraca** por não considerar informação que tipicamente está disponível ao adversário:
 - pares texto-limpo/criptograma (ataque de **texto-limpo conhecido**);
 - observar o efeito da cifra sobre mensagens por si escolhidas (ataque de **texto-limpo escolhido**).
- Com vista a “enriquecer” a noção de segurança considerada, acrescenta-se a possibilidade de o adversário recorrer a um **oráculo** que possibilite cifrar mensagens.

- O jogo IND-CPA (*indistinguishability under chosen plaintext attack*) é então definido como:

IND-CPA($\mathcal{A}$)	
1 :	$k \leftarrow \$ \text{KGen}(1^\lambda)$
2 :	$(m_0, m_1, \text{state}) \leftarrow \$ \mathcal{A}_1^{\text{Enc}_k}()$
3 :	$b \leftarrow \$ \{0, 1\}$
4 :	$c \leftarrow \$ \text{Enc}_k(m_b)$
5 :	$b' \leftarrow \$ \mathcal{A}_2^{\text{Enc}_k}(\text{state}, c)$
6 :	return $b = b'$

- A vantagem do adversário é definida como

$$\text{Adv}_{\mathcal{A}}^{\text{IND-CPA}} = |2 * \Pr[\text{IND-CPA}(\mathcal{A}) = \text{true}] - 1|$$

- Uma cifra exibe segurança IND-CPA se, para qualquer adversário $\mathcal{A} \in \text{PPT}$,

$$\text{Adv}_{\mathcal{A}}^{\text{IND-CPA}} \in \text{negl}(\lambda).$$

IND-CCA

- Uma noção de segurança mais forte surge quando disponibilizamos ao adversário um oráculo para decifrar criptogramas à sua escolha (condicionado a que não o aplique no “desafio” do jogo).
- O jogo IND-CCA (*indistinguishability under chosen ciphertext attack*) é definido como:

IND-CCA($\mathcal{A}$)	
1 :	$k \leftarrow \$ \text{KGen}(1^\lambda)$
2 :	$(m_0, m_1, \text{state}) \leftarrow \$ \mathcal{A}_1^{\text{Enc}_k, \text{Dec}_k}()$
3 :	$b \leftarrow \$ \{0, 1\}$
4 :	$c \leftarrow \$ \text{Enc}_k(m_b)$
5 :	$b' \leftarrow \$ \mathcal{A}_2^{\text{Enc}_k, \text{Dec}_k}(\text{state}, c)$
6 :	return $b = b' \wedge \text{Dec}_k(c)$ não foi invocado

Raciocinar sobre a segurança de cifras

- A forma mais directa de beneficiar das definições apresentadas é em resultados “pela negativa” (e.g. demonstrar a “insegurança” de uma cifra):

Para demonstrar a insegurança de uma cifra, é suficiente exhibir um adversário concreto A que obtenha uma vantagem de sucesso não negligenciável.

- Já a demonstração de segurança é tipicamente estabelecida por um *argumento de redução*

*Admitindo que existe um adversário A que obtém uma vantagem não negligenciável a atacar o jogo de segurança, constrói-se um adversário $B(A)$ que será capaz de atacar uma **assumpção** de segurança.*

Exemplos:

- Insegurança IND do modo ECB numa cifra de blocos (para mensagens com mais de que um bloco);
- Insegurança IND-CPA do modo ECB para cifrar um único bloco (obs: e, em geral, para qualquer cifra determinística...);
- Segurança IND-CPA do modo CTR\$ numa cifra por blocos (por redução à segurança da PRF subjacente);
- Insegurança IND-CCA do modo CTR numa cifra por blocos.

Integridade do Criptograma

- Para capturar a propriedade de integridade numa cifra, considera-se que a operação Dec possa falhar

$$\text{Dec} : \mathcal{K} \times \mathcal{C} \rightarrow \mathcal{M} \cup \perp$$

- Quando um criptograma não for rejeitado pela operação Dec (i.e. $\text{Dec}_k(c) \neq \perp$), diz-se que o criptograma é **válido**.
- Assim, para comprometer a integridade, o adversário irá procurar “forjar” um criptograma válido.
- *Verification Oracle*:

$$\text{Dec}_k^*(c) \triangleq (\text{Dec}_k(c) \neq \perp)$$

INT-PTXT

- A propriedade de “integridade de texto-limpo” (*plaintext integrity (INT-PTXT)*) estabelece a incapacidade de um adversário “forjar” um criptograma válido.
- Para “forjar” esse criptograma, possibilita-se que o adversário recorra a oráculos que:
 - permitem cifrar qualquer mensagem à sua escolha;
 - testar se criptogramas são válidos ou não.
- Mas, evidentemente, impõe-se restrições sobre o criptograma forjado: *o texto limpo correspondente não deverá ter sido submetido ao oráculo Enc_k .*

INT-PTXT($\mathcal{A}$)

1 : $k \leftarrow \$ \text{KGen}(1^\lambda)$

2 : $c \leftarrow \$ \mathcal{A}^{\text{Enc}_k, \text{Dec}_k^*}()$

3 : **return** $\text{Dec}_k(c) = m \wedge \text{Enc}_k(m)$ não foi invocado por $\mathcal{A}$

INT-CTXT

- Uma noção mais forte de integridade é obtida quando se relaxa a restrição sobre a utilização do oráculo para impedir somente que $\mathcal{A}$ não use directamente o resultado.
- Obtém-se assim o que se designa por “integridade do criptograma” (*ciphertext integrity* (INT-CTXT))

INT-CTXT($\mathcal{A}$)

```
1 :  $k \leftarrow \$ \text{KGen}(1^\lambda)$   
2 :  $c \leftarrow \$ \mathcal{A}^{\text{Enc}_k, \text{Dec}_k^*}()$   
3 : return  $\text{Dec}_k(c) = m \wedge c$  não foi obtido como resposta ao oráculo  $\text{Enc}_k$ 
```

- Note que INT-CTXT implica INT-PTXT (quando $\text{Enc}_k(\text{Dec}_k(c))$ não for invocado, então c não pode surgir como resposta).
- Por outro lado, INT-CTXT é estritamente mais forte que INT-PTXT (e.g. considerando um bit redundante no criptograma...)

Cifra Autenticada

- Numa cifra autenticada, pretende-se garantir simultaneamente *confidencialidade* e *integridade*.
- Pode ser conseguido combinando uma “cifra” com um “MAC”.
- Possíveis combinações genéricas:
 - *encrypt & MAC* – aplicar separadamente a cifra e MAC;
 - *MAC-then-encrypt* – cifra mensagem juntamente com *tag* de autenticação;
 - *encrypt-then-MAC* – aplica MAC sobre criptograma.
- Estas diferentes combinações resultam em garantias muito distintas.

- Considere-se:
 - Uma cifra que exiba segurança IND-CPA;
 - Um MAC que garanta INT-PTXT.
- Nesse caso, pode-se demonstrar que²:

	Confidencialidade	Integridade
<i>encrypt & MAC</i>	X	INT-PTXT
<i>MAC-then-encrypt</i>	IND-CPA	INT-PTXT
<i>encrypt-then-MAC</i>	IND-CCA	INT-CTXT

²Bellare & Namprempe, 2007 – Authenticated Encryption: Relations among notions and analysis of the generic composition paradigm